Báo cáo tích hợp Chương 6 — Specs → Kripke → Code → CWE/CVE → Ch1-5

Đặc tả: thanhtoan_donhang_v0

Mục lục

1. Đặc tả yêu cầu (Specification) 2

2. Chương 1 — Kiểm chứng hình thức (Kripke/CTL) 4

2.1. Sơ đồ chuyển trạng thái 9

3. Chương 2 — Mã C sinh ra & Static Checker 14

4. Chương 3 — Trích xuất AST/điều kiện & SMT (Z3) 15

4.0a. CFG (Control Flow Graph) từng hàm Python 16

4.0b. Call Graph (toàn bộ hàm Python sinh từ đặc tả) 16

4.0c. BMC (Bounded Model Checking) trên vòng lặp khai báo 16

4.1. Test case SINH TỰ ĐỘNG từ SMT (symbolic execution) 16

5. Chương 4 — Dynamic Fuzzing (hàm Python sinh ra) 17

5.0. Tham số TỰ ĐỘNG DETECT (theo tên biến) 17

5.1. Mutation fuzzing (seed tự sinh từ tham số đã detect) 17

5.2. Coverage tracking (line/branch, 1 lần chạy đại diện) 18

5.3. Test case sinh từ TẤT CẢ kiểu fuzzing (Python trực tiếp; C qua Python wrap) 18

6. Chương 5 — Phân loại LUỒNG Lập trình C/C++ an toàn 20

7. Chương 6 — Phân loại CWE/CVE tổng hợp 21

8. Test case truy vết từ đặc tả (tài liệu hóa) 25

1. Đặc tả yêu cầu (Specification)

Quy trình thanh toán trực tuyến 1 đơn hàng qua cổng thanh toán (có callback IPN), gồm 6 hành vi: H1 tiếp nhận yêu cầu (chép mã đơn vào bộ đệm), H2 tạo đơn (cấp phát mảng sản phẩm), H3 tính tổng tiền (số nguyên 32-bit, VND), H4 nhận callback từ cổng (chép mã giao dịch, xác thực chữ ký), H5 ghi log giao dịch, H6 đóng phiên (worker callback và worker timeout dùng chung phiên thanh toán). Bản v0 CÀI LỖI CÓ CHỦ ĐÍCH (18 trường hợp rủi ro bộ nhớ/tràn, trong đó 15 lỗi ẩn) để kiểm chứng khả năng phát hiện.

Mã yêu cầu	Loại	Ưu tiên	Nội dung
REQ-01	memory	HIGH	H1: Hàm phân tích mã đơn hàng (parse_order_id) không được ghi vượt biên bộ đệm, kể cả khi mã dài ĐÚNG 16 ký tự (C1.2, C1.3)
REQ-02	functional	HIGH	H1: Mã đơn hàng hợp lệ không được bị cắt cụt hoặc biến đổi khi lưu vào bộ đệm (C1.4)
REQ-03	memory	HIGH	H2: Kết quả cấp phát mảng sản phẩm (create_order_items) phải được kiểm tra NULL trước khi sử dụng (C2.2)
REQ-04	safety	HIGH	H2: Kích thước vùng nhớ cấp phát (số dòng x kích thước 1 dòng) không được tràn số hoặc âm (C2.3)
REQ-05	memory	MEDIUM	H2: Không được đọc trường dữ liệu của đơn hàng trước khi khởi tạo (C2.4)
REQ-06	safety	HIGH	H3: Tổng tiền đơn hàng không được tràn kiểu int32, kể cả khi cộng dồn nhiều dòng sản phẩm (C3.2, C3.3)
REQ-07	safety	HIGH	H3: Số lượng, đơn giá, giảm giá không được âm; tổng tiền phải thanh toán không được âm (C3.4)
REQ-08	functional	MEDIUM	H3: Hàm tính tiền trả góp không được gây lỗi không kiểm soát khi số kỳ hạn = 0 (C3.5)
REQ-09	memory	HIGH	H4: Hàm phân tích mã giao dịch từ callback (parse_gateway_txn_id) không được tràn bộ đệm (C4.2)

Mã yêu cầu	Loại	Ưu tiên	Nội dung
REQ-10	safety	HIGH	H4: Mọi callback phải được xác thực chữ ký; không được tồn tại nhánh ẩn bỏ qua kiểm tra (C4.3)
REQ-11	memory	MEDIUM	H5: Bản ghi log giao dịch (write_payment_log) phải được giải phóng trên mọi nhánh, kể cả nhánh lỗi (C5.2)
REQ-12	safety	MEDIUM	H5: Nội dung log có dữ liệu người dùng không được dùng làm chuỗi định dạng của printf (C5.3)
REQ-13	safety	HIGH	H6: Worker callback và worker timeout không được đồng thời giữ phiên thanh toán (mutual exclusion) (C6.2)
REQ-14	memory	HIGH	H6: Phiên thanh toán (close_payment_session) chỉ được giải phóng đúng 1 lần (C6.3)
REQ-15	memory	HIGH	H6: Không được truy cập phiên/bộ đệm thẻ (release_card_buffer) sau khi đã giải phóng (C6.4)
REQ-16	safety	HIGH	H6: Dữ liệu thẻ phải được xóa trắng bằng lệnh không bị trình biên dịch loại bỏ trước khi giải phóng (C6.5)
REQ-17	liveness	HIGH	Toàn luồng: mọi đường xử lý thanh toán cuối cùng phải kết thúc (thành công hoặc từ chối an toàn), không dừng ở trạng thái không an toàn
REQ-18	liveness	MEDIUM	Toàn luồng: luồng thanh toán thành công phải đạt tới được (mô hình không tầm thường) và đầu vào xấu phải có nhánh từ chối
NFR-01	non_functional	MEDIUM	Hệ thống xử lý tối thiểu 200 yêu cầu thanh toán/giây trên phần cứng tham chiếu

Mã yêu cầu	Loại	Ưu tiên	Nội dung
NFR-02	non_functional	HIGH	Phản hồi callback cho cổng thanh toán trong tối đa 3 giây (quá hạn cổng sẽ gửi lại IPN, gây callback lặp)
NFR-03	non_functional	HIGH	Bộ nhớ tiến trình không tăng quá 5% sau 1.000.000 giao dịch liên tiếp (dấu hiệu rò rỉ bộ nhớ)
NFR-04	non_functional	MEDIUM	Phiên thanh toán tự hết hạn sau 15 phút nếu không nhận được callback (worker timeout)
NFR-05	non_functional	HIGH	Dữ liệu thẻ không được tồn tại trong bộ nhớ quá thời gian xử lý 1 giao dịch (tinh thần PCI-DSS)
NFR-06	non_functional	LOW	Log giao dịch được lưu tối thiểu 12 tháng để đối soát
CON-01	constraint	HIGH	Mã đơn hàng tối đa 16 ký tự ASCII (16 ký tự cần 17 byte kể cả '\0')
CON-02	constraint	HIGH	Mã giao dịch của cổng thanh toán tối đa 20 ký tự ASCII
CON-03	constraint	HIGH	Mỗi đơn có 1–100 dòng sản phẩm; số lượng mỗi dòng 1–1000; đơn giá 0–50.000.000 VND; giá trị mỗi dòng tối đa 50.000.000 VND
CON-04	constraint	HIGH	Số tiền tính bằng VND; bản v0 dùng int 32-bit có dấu (tối đa 2.147.483.647); hạn mức 1 đơn là 2.000.000.000 VND
CON-05	constraint	MEDIUM	Kỳ hạn trả góp từ 1 đến 24 tháng
CON-06	constraint	MEDIUM	Chỉ dùng thư viện chuẩn C; phiên thanh toán được bảo vệ bằng mutex nhẹ
CON-07	constraint	HIGH	Bộ đệm số thẻ (PAN) 16 chữ số, chỉ tồn tại trong thời gian xử lý giao dịch

2. Chương 1 — Kiểm chứng hình thức (Kripke/CTL)

Trạng thái deadlock: không có

Công thức CTL	Kết quả	Trạng thái thỏa
AG(!violation)	VI PHẠM	dung_khong_an_toan, ket_thuc_ok, ket_thuc_tu_choi
AG(!buffer_overflow)	VI PHẠM	dung_khong_an_toan, h2_doc_rac, h2_null, h2_sai_kich_thuoc, h3_chia_0, h3_so_am, h3_tran_so, h4_nhanh_an, h4_ok, h4_tu_choi_callback, h5_format_string, h5_ok, h5_ro_ri, h5_vao, h6_cb_giu, h6_con_so_the, h6_double_free, h6_giai_phong, h6_phien_ranh, h6_to_giu, h6_tranh_chap, h6_uaf, ket_thuc_ok, ket_thuc_tu_choi
AG(!off_by_one)	VI PHẠM	dung_khong_an_toan, h1_ok, h1_tran_bo_dem, h2_doc_rac, h2_null, h2_ok, h2_sai_kich_thuoc, h2_vao, h3_chia_0, h3_ok, h3_so_am, h3_tran_so, h3_vao, h4_nhanh_an, h4_ok, h4_tran_txn, h4_tu_choi_callback, h4_vao, h5_format_string, h5_ok, h5_ro_ri, h5_vao, h6_cb_giu, h6_con_so_the, h6_double_free, h6_giai_phong, h6_phien_ranh, h6_to_giu, h6_tranh_chap, h6_uaf, ket_thuc_ok, ket_thuc_tu_choi
AG(!null_deref)	VI PHẠM	dung_khong_an_toan, h1_tran_1_byte, h1_tran_bo_dem, h2_doc_rac, h2_ok, h2_sai_kich_thuoc, h3_chia_0, h3_ok, h3_so_am, h3_tran_so, h3_vao, h4_nhanh_an, h4_ok, h4_tran_txn, h4_tu_choi_callback, h4_vao, h5_format_string, h5_ok, h5_ro_ri, h5_vao, h6_cb_giu, h6_con_so_the, h6_double_free, h6_giai_phong, h6_phien_ranh, h6_to_giu, h6_tranh_chap, h6_uaf, ket_thuc_ok, ket_thuc_tu_choi

Công thức CTL	Kết quả	Trạng thái thỏa
AG(!heap_overflow)	VI PHẠM	dung_khong_an_toan, h1_tran_1_byte, h1_tran_bo_dem, h2_doc_rac, h2_null, h2_ok, h3_chia_0, h3_ok, h3_so_am, h3_tran_so, h3_vao, h4_nhanh_an, h4_ok, h4_tran_txn, h4_tu_choi_callback, h4_vao, h5_format_string, h5_ok, h5_ro_ri, h5_vao, h6_cb_giu, h6_con_so_the, h6_double_free, h6_giai_phong, h6_phien_ranh, h6_to_giu, h6_tranh_chap, h6_uaf, ket_thuc_ok, ket_thuc_tu_choi
AG(!uninit_read)	VI PHẠM	dung_khong_an_toan, h1_tran_1_byte, h1_tran_bo_dem, h2_null, h2_ok, h2_sai_kich_thuoc, h3_chia_0, h3_ok, h3_so_am, h3_tran_so, h3_vao, h4_nhanh_an, h4_ok, h4_tran_txn, h4_tu_choi_callback, h4_vao, h5_format_string, h5_ok, h5_ro_ri, h5_vao, h6_cb_giu, h6_con_so_the, h6_double_free, h6_giai_phong, h6_phien_ranh, h6_to_giu, h6_tranh_chap, h6_uaf, ket_thuc_ok, ket_thuc_tu_choi
AG(!int_overflow)	VI PHẠM	dung_khong_an_toan, h1_tran_1_byte, h1_tran_bo_dem, h2_doc_rac, h2_null, h2_sai_kich_thuoc, h3_chia_0, h3_ok, h3_so_am, h4_nhanh_an, h4_ok, h4_tran_txn, h4_tu_choi_callback, h4_vao, h5_format_string, h5_ok, h5_ro_ri, h5_vao, h6_cb_giu, h6_con_so_the, h6_double_free, h6_giai_phong, h6_phien_ranh, h6_to_giu, h6_tranh_chap, h6_uaf, ket_thuc_ok, ket_thuc_tu_choi

Công thức CTL	Kết quả	Trạng thái thỏa
AG(!negative_amount)	VI PHẠM	dung_khong_an_toan, h1_tran_1_byte, h1_tran_bo_dem, h2_doc_rac, h2_null, h2_sai_kich_thuoc, h3_chia_0, h3_ok, h3_tran_so, h4_nhanh_an, h4_ok, h4_tran_txn, h4_tu_choi_callback, h4_vao, h5_format_string, h5_ok, h5_ro_ri, h5_vao, h6_cb_giu, h6_con_so_the, h6_double_free, h6_giai_phong, h6_phien_ranh, h6_to_giu, h6_tranh_chap, h6_uaf, ket_thuc_ok, ket_thuc_tu_choi
AG(!div_by_zero)	VI PHẠM	dung_khong_an_toan, h1_tran_1_byte, h1_tran_bo_dem, h2_doc_rac, h2_null, h2_sai_kich_thuoc, h3_ok, h3_so_am, h3_tran_so, h4_nhanh_an, h4_ok, h4_tran_txn, h4_tu_choi_callback, h4_vao, h5_format_string, h5_ok, h5_ro_ri, h5_vao, h6_cb_giu, h6_con_so_the, h6_double_free, h6_giai_phong, h6_phien_ranh, h6_to_giu, h6_tranh_chap, h6_uaf, ket_thuc_ok, ket_thuc_tu_choi
AG(!hidden_bypass)	VI PHẠM	dung_khong_an_toan, h1_tran_1_byte, h1_tran_bo_dem, h2_doc_rac, h2_null, h2_sai_kich_thuoc, h3_chia_0, h3_so_am, h3_tran_so, h4_ok, h4_tran_txn, h4_tu_choi_callback, h5_format_string, h5_ok, h5_ro_ri, h5_vao, h6_cb_giu, h6_con_so_the, h6_double_free, h6_giai_phong, h6_phien_ranh, h6_to_giu, h6_tranh_chap, h6_uaf, ket_thuc_ok, ket_thuc_tu_choi

Công thức CTL	Kết quả	Trạng thái thỏa
AG(!mem_leak)	VI PHẠM	dung_khong_an_toan, h1_tran_1_byte, h1_tran_bo_dem, h2_doc_rac, h2_null, h2_sai_kich_thuoc, h3_chia_0, h3_so_am, h3_tran_so, h4_nhanh_an, h4_tran_txn, h4_tu_choi_callback, h5_format_string, h5_ok, h6_cb_giu, h6_con_so_the, h6_double_free, h6_giai_phong, h6_phien_ranh, h6_to_giu, h6_tranh_chap, h6_uaf, ket_thuc_ok, ket_thuc_tu_choi
AG(!format_string)	VI PHẠM	dung_khong_an_toan, h1_tran_1_byte, h1_tran_bo_dem, h2_doc_rac, h2_null, h2_sai_kich_thuoc, h3_chia_0, h3_so_am, h3_tran_so, h4_nhanh_an, h4_tran_txn, h4_tu_choi_callback, h5_ok, h5_ro_ri, h6_cb_giu, h6_con_so_the, h6_double_free, h6_giai_phong, h6_phien_ranh, h6_to_giu, h6_tranh_chap, h6_uaf, ket_thuc_ok, ket_thuc_tu_choi
AG(!race)	VI PHẠM	dung_khong_an_toan, h1_tran_1_byte, h1_tran_bo_dem, h2_doc_rac, h2_null, h2_sai_kich_thuoc, h3_chia_0, h3_so_am, h3_tran_so, h4_nhanh_an, h4_tran_txn, h5_format_string, h5_ro_ri, h6_con_so_the, h6_double_free, h6_giai_phong, h6_uaf, ket_thuc_ok, ket_thuc_tu_choi
AG(!double_free)	VI PHẠM	dung_khong_an_toan, h1_tran_1_byte, h1_tran_bo_dem, h2_doc_rac, h2_null, h2_sai_kich_thuoc, h3_chia_0, h3_so_am, h3_tran_so, h4_nhanh_an, h4_tran_txn, h5_format_string, h5_ro_ri, h6_con_so_the, h6_giai_phong, h6_uaf, ket_thuc_ok, ket_thuc_tu_choi

Công thức CTL	Kết quả	Trạng thái thỏa
AG(!use_after_free)	VI PHẠM	dung_khong_an_toan, h1_tran_1_byte, h1_tran_bo_dem, h2_doc_rac, h2_null, h2_sai_kich_thuoc, h3_chia_0, h3_so_am, h3_tran_so, h4_nhanh_an, h4_tran_txn, h5_format_string, h5_ro_ri, h6_con_so_the, h6_double_free, h6_giai_phong, ket_thuc_ok, ket_thuc_tu_choi
AG(!secret_residue)	VI PHẠM	dung_khong_an_toan, h1_tran_1_byte, h1_tran_bo_dem, h2_doc_rac, h2_null, h2_sai_kich_thuoc, h3_chia_0, h3_so_am, h3_tran_so, h4_nhanh_an, h4_tran_txn, h5_format_string, h5_ro_ri, h6_double_free, h6_tranh_chap, h6_uaf, ket_thuc_ok, ket_thuc_tu_choi
AF(flow_end)	VI PHẠM	ket_thuc_ok, ket_thuc_tu_choi
EF(payment_done)	ĐÚNG	h1_ok, h1_vao, h2_ok, h2_vao, h3_ok, h3_vao, h4_ok, h4_tu_choi_callback, h4_vao, h5_ok, h5_vao, h6_cb_giu, h6_giai_phong, h6_phien_ranh, h6_to_giu, ket_thuc_ok, start
EF(input_rejected)	VI PHẠM	ket_thuc_tu_choi
EG(!violation)	ĐÚNG	dung_khong_an_toan, h1_ok, h1_vao, h2_ok, h2_vao, h3_ok, h3_vao, h4_ok, h4_tu_choi_callback, h4_vao, h5_ok, h5_vao, h6_cb_giu, h6_giai_phong, h6_phien_ranh, h6_to_giu, ket_thuc_ok, ket_thuc_tu_choi, start
EF(cb_locked)	ĐÚNG	h1_ok, h1_vao, h2_ok, h2_vao, h3_ok, h3_vao, h4_ok, h4_tu_choi_callback, h4_vao, h5_ok, h5_vao, h6_cb_giu, h6_phien_ranh, h6_to_giu, h6_tranh_chap, start

Mutual exclusion: VI PHẠM (trạng thái nguy hiểm: h1_ok, h1_vao, h2_ok, h2_vao, h3_ok, h3_vao, h4_ok, h4_tu_choi_callback, h4_vao, h5_ok, h5_vao, h6_cb_giu, h6_phien_ranh, h6_to_giu, h6_tranh_chap, start)

2.1. Sơ đồ chuyển trạng thái

Sơ đồ: Mô hình chính: thanhtoan_donhang_v0

Mã TikZ (LaTeX) — dán trực tiếp vào tài liệu LaTeX có \usepackage{tikz} để biên dịch thành hình vector, thay cho ảnh tĩnh:

```
% Mô hình chính: thanhtoan_donhang_v0
\begin{tikzpicture}[
every node/.style={draw, circle, inner sep=2pt,
minimum size=8mm, align=center, font=\scriptsize},
->, >=stealth, thick, auto
]
\node[fill=red!35] (nd_h3_tran_so) at (-0.08,1.99) {h3\_tran\_so\\{\tiny h3,int\_overflow,violation}};
\node[fill=red!35] (nd_h3_so_am) at (1.52,0.95) {h3\_so\_am\\{\tiny h3,negative\_amount,violation}};
\node[fill=red!35] (nd_h6_double_free) at (-1.30,-1.44) {h6\_double\_free\\{\tiny double\_free,h6,violation}};
\node[fill=gray!15] (nd_h2_vao) at (-0.74,0.74) {h2\_vao\\{\tiny allocating,h2}};
\node[fill=red!35] (nd_h5_format_string) at (0.53,1.36) {h5\_format\_string\\{\tiny format\_string,h5,violation}};
\node[fill=red!35] (nd_h2_doc_rac) at (-1.44,1.48) {h2\_doc\_rac\\{\tiny h2,uninit\_read,violation}};
\node[fill=gray!15] (nd_h1_ok) at (1.30,-0.90) {h1\_ok\\{\tiny h1,input\_ok}};
\node[fill=gray!15] (nd_h6_cb_giu) at (-0.96,-1.64) {h6\_cb\_giu\\{\tiny cb\_locked,h6}};
\node[fill=gray!15] (nd_ket_thuc_tu_choi) at (-1.37,-0.73) {ket\_thuc\_tu\_choi\\{\tiny
flow\_end,input\_rejected,mem\_clean}};
\node[fill=gray!15] (nd_h6_phien_ranh) at (0.08,-1.52) {h6\_phien\_ranh\\{\tiny h6,sess\_free}};
\node[fill=red!35] (nd_h1_tran_1_byte) at (0.61,-1.59) {h1\_tran\_1\_byte\\{\tiny
buffer\_overflow,h1,off\_by\_one,violation}};
\node[fill=red!35] (nd_h6_tranh_chap) at (0.24,-0.25) {h6\_tranh\_chap\\{\tiny cb\_locked,h6,race,to\_locked,violation}};
\node[fill=gray!15] (nd_h4_vao) at (0.82,0.63) {h4\_vao\\{\tiny callback\_received,h4}};
\node[fill=gray!15] (nd_dung_khong_an_toan) at (-1.73,0.15) {dung\_khong\_an\_toan\\{\tiny unsafe\_halt}};
\node[fill=red!35] (nd_h3_chia_0) at (0.40,-2.03) {h3\_chia\_0\\{\tiny div\_by\_zero,h3,violation}};
\node[fill=gray!15] (nd_h4_tu_choi_callback) at (1.59,-1.47) {h4\_tu\_choi\_callback\\{\tiny callback\_rejected,h4}};
\node[fill=gray!15] (nd_h4_ok) at (-1.01,1.79) {h4\_ok\\{\tiny callback\_verified,h4}};
\node[fill=gray!15] (nd_h2_ok) at (2.20,0.96) {h2\_ok\\{\tiny allocated,h2,initialized}};
\node[fill=gray!15] (nd_h3_ok) at (-0.52,-1.86) {h3\_ok\\{\tiny amount\_ok,h3}};
\node[fill=gray!15] (nd_h5_ok) at (2.06,-0.55) {h5\_ok\\{\tiny h5,log\_freed}};
\node[fill=gray!15] (nd_h5_vao) at (-0.02,-0.25) {h5\_vao\\{\tiny h5,logging}};
\node[fill=red!35] (nd_h2_null) at (-1.72,0.93) {h2\_null\\{\tiny h2,null\_deref,violation}};
\node[fill=red!35] (nd_h1_tran_bo_dem) at (-0.61,1.53) {h1\_tran\_bo\_dem\\{\tiny buffer\_overflow,h1,violation}};
\node[fill=blue!25] (nd_start) at (1.39,0.96) {start\\{\tiny safe,start}};
\node[fill=red!35] (nd_h5_ro_ri) at (0.02,-1.96) {h5\_ro\_ri\\{\tiny h5,mem\_leak,violation}};
\node[fill=gray!15] (nd_h3_vao) at (1.25,-0.18) {h3\_vao\\{\tiny computing,h3}};
\node[fill=red!35] (nd_h6_uaf) at (0.99,1.71) {h6\_uaf\\{\tiny h6,use\_after\_free,violation}};
\node[fill=red!35] (nd_h4_nhanh_an) at (0.36,1.86) {h4\_nhanh\_an\\{\tiny h4,hidden\_bypass,violation}};
\node[fill=gray!15] (nd_h6_to_giu) at (-1.59,-1.11) {h6\_to\_giu\\{\tiny h6,to\_locked}};
\node[fill=gray!15] (nd_h6_giai_phong) at (-1.77,-0.22) {h6\_giai\_phong\\{\tiny h6,releasing}};
\node[fill=gray!15] (nd_ket_thuc_ok) at (-0.16,-1.91) {ket\_thuc\_ok\\{\tiny flow\_end,mem\_clean,payment\_done}};
\node[fill=red!35] (nd_h4_tran_txn) at (1.09,-0.57) {h4\_tran\_txn\\{\tiny buffer\_overflow,h4,violation}};
\node[fill=red!35] (nd_h2_sai_kich_thuoc) at (-1.33,1.05) {h2\_sai\_kich\_thuoc\\{\tiny
alloc\_size\_overflow,h2,heap\_overflow,violation}};
\node[fill=gray!15] (nd_h1_vao) at (0.47,0.11) {h1\_vao\\{\tiny h1,receiving}};
\node[fill=red!35] (nd_h6_con_so_the) at (-0.57,1.99) {h6\_con\_so\_the\\{\tiny h6,secret\_residue,violation}};
\draw (nd_h3_tran_so) -- (nd_dung_khong_an_toan);
\draw (nd_h3_so_am) -- (nd_dung_khong_an_toan);
\draw (nd_h6_double_free) -- (nd_dung_khong_an_toan);
\draw (nd_h2_vao) -- (nd_h2_ok);
\draw (nd_h2_vao) -- (nd_h2_sai_kich_thuoc);
\draw (nd_h2_vao) -- (nd_h2_doc_rac);
\draw (nd_h2_vao) -- (nd_h2_null);
\draw (nd_h5_format_string) -- (nd_dung_khong_an_toan);
\draw (nd_h2_doc_rac) -- (nd_dung_khong_an_toan);
\draw (nd_h1_ok) -- (nd_h2_vao);
\draw (nd_h6_cb_giu) -- (nd_h6_tranh_chap);
\draw (nd_h6_cb_giu) -- (nd_h6_giai_phong);
\draw (nd_ket_thuc_tu_choi) -- (nd_ket_thuc_tu_choi);
\draw (nd_h6_phien_ranh) -- (nd_h6_cb_giu);
\draw (nd_h6_phien_ranh) -- (nd_h6_to_giu);
\draw (nd_h1_tran_1_byte) -- (nd_dung_khong_an_toan);
\draw (nd_h6_tranh_chap) -- (nd_h6_double_free);
\draw (nd_h6_tranh_chap) -- (nd_h6_uaf);
\draw (nd_h4_vao) -- (nd_h4_nhanh_an);
\draw (nd_h4_vao) -- (nd_h4_ok);
\draw (nd_h4_vao) -- (nd_h4_tran_txn);
\draw (nd_h4_vao) -- (nd_h4_tu_choi_callback);
```

```
\draw (nd_dung_khong_an_toan) -- (nd_dung_khong_an_toan);
\draw (nd_h3_chia_0) -- (nd_dung_khong_an_toan);
\draw (nd_h4_tu_choi_callback) -- (nd_h6_phien_ranh);
\draw (nd_h4_ok) -- (nd_h5_vao);
\draw (nd_h2_ok) -- (nd_h3_vao);
\draw (nd_h3_ok) -- (nd_h4_vao);
\draw (nd_h5_ok) -- (nd_h6_phien_ranh);
\draw (nd_h5_vao) -- (nd_h5_ro_ri);
\draw (nd_h5_vao) -- (nd_h5_ok);
\draw (nd_h5_vao) -- (nd_h5_format_string);
\draw (nd_h2_null) -- (nd_dung_khong_an_toan);
\draw (nd_h1_tran_bo_dem) -- (nd_dung_khong_an_toan);
\draw (nd_start) -- (nd_h1_vao);
\draw (nd_h5_ro_ri) -- (nd_dung_khong_an_toan);
\draw (nd_h3_vao) -- (nd_h3_ok);
\draw (nd_h3_vao) -- (nd_h3_so_am);
\draw (nd_h3_vao) -- (nd_h3_tran_so);
\draw (nd_h3_vao) -- (nd_h3_chia_0);
\draw (nd_h6_uaf) -- (nd_dung_khong_an_toan);
\draw (nd_h4_nhanh_an) -- (nd_dung_khong_an_toan);
\draw (nd_h6_to_giu) -- (nd_h6_giai_phong);
\draw (nd_h6_to_giu) -- (nd_h6_tranh_chap);
\draw (nd_h6_giai_phong) -- (nd_ket_thuc_ok);
\draw (nd_h6_giai_phong) -- (nd_h6_con_so_the);
\draw (nd_ket_thuc_ok) -- (nd_ket_thuc_ok);
\draw (nd_h4_tran_txn) -- (nd_dung_khong_an_toan);
\draw (nd_h2_sai_kich_thuoc) -- (nd_dung_khong_an_toan);
\draw (nd_h1_vao) -- (nd_h1_tran_bo_dem);
\draw (nd_h1_vao) -- (nd_h1_ok);
\draw (nd_h1_vao) -- (nd_h1_tran_1_byte);
\draw (nd_h6_con_so_the) -- (nd_dung_khong_an_toan);
\end{tikzpicture}
```

Sơ đồ: M1-v0: strcpy vào order_id[16] (CÓ LỖI)

Mã TikZ (LaTeX) — dán trực tiếp vào tài liệu LaTeX có \usepackage{tikz} để biên dịch thành hình vector, thay cho ảnh tĩnh:

```
% M1-v0: strcpy vào order_id[16] (CÓ LỖI)
\begin{tikzpicture}[
every node/.style={draw, circle, inner sep=2pt,
minimum size=8mm, align=center, font=\scriptsize},
->, >=stealth, thick, auto
]
\node[fill=gray!15] (nd_m1_len_nho) at (-0.42,0.23) {m1\_len\_nho\\{\tiny len\_lt\_cap}};
\node[fill=red!35] (nd_m1_tran_1_byte) at (2.20,0.42) {m1\_tran\_1\_byte\\{\tiny
buffer\_overflow,off\_by\_one,violation}};
\node[fill=gray!15] (nd_m1_chep_dung) at (-0.65,-1.64) {m1\_chep\_dung\\{\tiny copied\_ok,done}};
\node[fill=red!35] (nd_m1_tran_nhieu_byte) at (-1.71,-0.01) {m1\_tran\_nhieu\_byte\\{\tiny buffer\_overflow,violation}};
\node[fill=blue!25] (nd_m1_nhan_chuoi) at (0.31,0.48) {m1\_nhan\_chuoi\\{\tiny receiving}};
\node[fill=gray!15] (nd_m1_len_lon) at (-1.62,1.41) {m1\_len\_lon\\{\tiny len\_gt\_cap}};
\node[fill=gray!15] (nd_m1_len_bang_16) at (1.89,-0.89) {m1\_len\_bang\_16\\{\tiny len\_eq\_cap}};
\draw (nd_m1_len_nho) -- (nd_m1_chep_dung);
\draw (nd_m1_tran_1_byte) -- (nd_m1_tran_1_byte);
\draw (nd_m1_chep_dung) -- (nd_m1_chep_dung);
\draw (nd_m1_tran_nhieu_byte) -- (nd_m1_tran_nhieu_byte);
\draw (nd_m1_nhan_chuoi) -- (nd_m1_len_bang_16);
\draw (nd_m1_nhan_chuoi) -- (nd_m1_len_nho);
\draw (nd_m1_nhan_chuoi) -- (nd_m1_len_lon);
\draw (nd_m1_len_lon) -- (nd_m1_tran_nhieu_byte);
\draw (nd_m1_len_bang_16) -- (nd_m1_tran_1_byte);
\end{tikzpicture}
```

Sơ đồ: M2-v0: malloc không kiểm tra (CÓ LỖI)

Mã TikZ (LaTeX) — dán trực tiếp vào tài liệu LaTeX có \usepackage{tikz} để biên dịch thành hình vector, thay cho ảnh tĩnh:

```
% M2-v0: malloc không kiểm tra (CÓ LỖI)
\begin{tikzpicture}[
every node/.style={draw, circle, inner sep=2pt,
minimum size=8mm, align=center, font=\scriptsize},
```

```
->, >=stealth, thick, auto
]
\node[fill=gray!15] (nd_m2_cap_phat_chua_kt) at (-1.09,1.68) {m2\_cap\_phat\_chua\_kt\\{\tiny allocated,uninitialized}};
\node[fill=gray!15] (nd_m2_malloc_null) at (1.98,0.83) {m2\_malloc\_null\\{\tiny ptr\_null}};
\node[fill=gray!15] (nd_m2_n_hop_le) at (-0.15,0.27) {m2\_n\_hop\_le\\{\tiny size\_ok}};
\node[fill=blue!25] (nd_m2_nhan_n) at (-1.26,-0.15) {m2\_nhan\_n\\{\tiny receiving}};
\node[fill=red!35] (nd_m2_null_deref) at (1.21,1.94) {m2\_null\_deref\\{\tiny null\_deref,violation}};
\node[fill=gray!15] (nd_m2_da_khoi_tao) at (0.12,0.80) {m2\_da\_khoi\_tao\\{\tiny allocated,initialized}};
\node[fill=gray!15] (nd_m2_su_dung) at (1.91,-1.13) {m2\_su\_dung\\{\tiny done,in\_use}};
\node[fill=red!35] (nd_m2_tran_heap) at (-0.90,-1.93) {m2\_tran\_heap\\{\tiny heap\_overflow,violation}};
\node[fill=red!35] (nd_m2_doc_rac) at (-2.20,-0.40) {m2\_doc\_rac\\{\tiny uninit\_read,violation}};
\node[fill=gray!15] (nd_m2_n_bat_thuong) at (0.38,-1.92) {m2\_n\_bat\_thuong\\{\tiny size\_wrong}};
\draw (nd_m2_cap_phat_chua_kt) -- (nd_m2_doc_rac);
\draw (nd_m2_cap_phat_chua_kt) -- (nd_m2_da_khoi_tao);
\draw (nd_m2_malloc_null) -- (nd_m2_null_deref);
\draw (nd_m2_n_hop_le) -- (nd_m2_malloc_null);
\draw (nd_m2_n_hop_le) -- (nd_m2_cap_phat_chua_kt);
\draw (nd_m2_nhan_n) -- (nd_m2_n_hop_le);
\draw (nd_m2_nhan_n) -- (nd_m2_n_bat_thuong);
\draw (nd_m2_null_deref) -- (nd_m2_null_deref);
\draw (nd_m2_da_khoi_tao) -- (nd_m2_su_dung);
\draw (nd_m2_su_dung) -- (nd_m2_su_dung);
\draw (nd_m2_tran_heap) -- (nd_m2_tran_heap);
\draw (nd_m2_doc_rac) -- (nd_m2_doc_rac);
\draw (nd_m2_n_bat_thuong) -- (nd_m2_tran_heap);
\end{tikzpicture}
```

Sơ đồ: M3-v0: int32, không kiểm tra miền (CÓ LỖI)

Mã TikZ (LaTeX) — dán trực tiếp vào tài liệu LaTeX có \usepackage{tikz} để biên dịch thành hình vector, thay cho ảnh tĩnh:

```
% M3-v0: int32, không kiểm tra miền (CÓ LỖI)
\begin{tikzpicture}[
every node/.style={draw, circle, inner sep=2pt,
minimum size=8mm, align=center, font=\scriptsize},
->, >=stealth, thick, auto
]
\node[fill=blue!25] (nd_m3_nhan_du_lieu) at (0.02,0.40) {m3\_nhan\_du\_lieu\\{\tiny receiving}};
\node[fill=red!35] (nd_m3_tong_am) at (2.02,0.59) {m3\_tong\_am\\{\tiny negative\_amount,violation}};
\node[fill=gray!15] (nd_m3_dau_vao_am) at (0.15,-0.63) {m3\_dau\_vao\_am\\{\tiny negative\_input}};
\node[fill=red!35] (nd_m3_tran_cong_don) at (-1.89,1.24) {m3\_tran\_cong\_don\\{\tiny int\_overflow,violation}};
\node[fill=gray!15] (nd_m3_dau_vao_hop_le) at (1.21,0.21) {m3\_dau\_vao\_hop\_le\\{\tiny input\_ok}};
\node[fill=gray!15] (nd_m3_tong_hop_le) at (-0.94,2.20) {m3\_tong\_hop\_le\\{\tiny amount\_ok,done}};
\node[fill=red!35] (nd_m3_tran_nhan) at (2.02,-0.82) {m3\_tran\_nhan\\{\tiny int\_overflow,violation}};
\node[fill=gray!15] (nd_m3_cong_don) at (-1.72,0.12) {m3\_cong\_don\\{\tiny accumulating}};
\node[fill=gray!15] (nd_m3_ky_han_0) at (-1.11,-0.34) {m3\_ky\_han\_0\\{\tiny zero\_divisor}};
\node[fill=red!35] (nd_m3_chia_0) at (-0.02,-1.86) {m3\_chia\_0\\{\tiny div\_by\_zero,violation}};
\node[fill=gray!15] (nd_m3_nhan_dong) at (0.26,-1.12) {m3\_nhan\_dong\\{\tiny multiplying}};
\draw (nd_m3_nhan_du_lieu) -- (nd_m3_dau_vao_hop_le);
\draw (nd_m3_nhan_du_lieu) -- (nd_m3_dau_vao_am);
\draw (nd_m3_nhan_du_lieu) -- (nd_m3_ky_han_0);
\draw (nd_m3_tong_am) -- (nd_m3_tong_am);
\draw (nd_m3_dau_vao_am) -- (nd_m3_tong_am);
\draw (nd_m3_tran_cong_don) -- (nd_m3_tran_cong_don);
\draw (nd_m3_dau_vao_hop_le) -- (nd_m3_nhan_dong);
\draw (nd_m3_tong_hop_le) -- (nd_m3_tong_hop_le);
\draw (nd_m3_tran_nhan) -- (nd_m3_tran_nhan);
\draw (nd_m3_cong_don) -- (nd_m3_tran_cong_don);
\draw (nd_m3_cong_don) -- (nd_m3_tong_hop_le);
\draw (nd_m3_ky_han_0) -- (nd_m3_chia_0);
\draw (nd_m3_chia_0) -- (nd_m3_chia_0);
\draw (nd_m3_nhan_dong) -- (nd_m3_cong_don);
\draw (nd_m3_nhan_dong) -- (nd_m3_tran_nhan);
\end{tikzpicture}
```

Sơ đồ: M4-v0: strcpy txn_id[20] + nhánh debug (CÓ LỖI)

Mã TikZ (LaTeX) — dán trực tiếp vào tài liệu LaTeX có \usepackage{tikz} để biên dịch thành hình vector, thay cho ảnh tĩnh:

```
% M4-v0: strcpy txn_id[20] + nhánh debug (CÓ LỖI)
```

```
\begin{tikzpicture}[
every node/.style={draw, circle, inner sep=2pt,
minimum size=8mm, align=center, font=\scriptsize},
->, >=stealth, thick, auto
]
\node[fill=gray!15] (nd_m4_txn_hop_le) at (0.46,1.97) {m4\_txn\_hop\_le\\{\tiny len\_ok}};
\node[fill=gray!15] (nd_m4_kiem_chu_ky) at (-0.36,0.11) {m4\_kiem\_chu\_ky\\{\tiny verifying}};
\node[fill=gray!15] (nd_m4_txn_qua_dai) at (-0.31,-1.74) {m4\_txn\_qua\_dai\\{\tiny len\_gt\_cap}};
\node[fill=blue!25] (nd_m4_nhan_callback) at (-1.07,0.34) {m4\_nhan\_callback\\{\tiny receiving}};
\node[fill=red!35] (nd_m4_nhanh_an) at (1.62,1.76) {m4\_nhanh\_an\\{\tiny hidden\_bypass,violation}};
\node[fill=gray!15] (nd_m4_chu_ky_dung) at (-0.47,0.71) {m4\_chu\_ky\_dung\\{\tiny verified}};
\node[fill=red!35] (nd_m4_tran_txn) at (1.91,-1.03) {m4\_tran\_txn\\{\tiny buffer\_overflow,violation}};
\node[fill=gray!15] (nd_m4_chap_nhan) at (0.43,-1.70) {m4\_chap\_nhan\\{\tiny accepted,done}};
\node[fill=gray!15] (nd_m4_tu_choi) at (-2.20,-0.41) {m4\_tu\_choi\\{\tiny callback\_rejected,done}};
\draw (nd_m4_txn_hop_le) -- (nd_m4_nhanh_an);
\draw (nd_m4_txn_hop_le) -- (nd_m4_kiem_chu_ky);
\draw (nd_m4_kiem_chu_ky) -- (nd_m4_tu_choi);
\draw (nd_m4_kiem_chu_ky) -- (nd_m4_chu_ky_dung);
\draw (nd_m4_txn_qua_dai) -- (nd_m4_tran_txn);
\draw (nd_m4_nhan_callback) -- (nd_m4_txn_hop_le);
\draw (nd_m4_nhan_callback) -- (nd_m4_txn_qua_dai);
\draw (nd_m4_nhanh_an) -- (nd_m4_nhanh_an);
\draw (nd_m4_chu_ky_dung) -- (nd_m4_chap_nhan);
\draw (nd_m4_tran_txn) -- (nd_m4_tran_txn);
\draw (nd_m4_chap_nhan) -- (nd_m4_chap_nhan);
\draw (nd_m4_tu_choi) -- (nd_m4_tu_choi);
\end{tikzpicture}
```

Sơ đồ: M5-v0: printf(msg) + return sớm (CÓ LỖI)

Mã TikZ (LaTeX) — dán trực tiếp vào tài liệu LaTeX có \usepackage{tikz} để biên dịch thành hình vector, thay cho ảnh tĩnh:

```
% M5-v0: printf(msg) + return sớm (CÓ LỖI)
\begin{tikzpicture}[
every node/.style={draw, circle, inner sep=2pt,
minimum size=8mm, align=center, font=\scriptsize},
->, >=stealth, thick, auto
]
\node[fill=gray!15] (nd_m5_ghi_noi_dung) at (-0.52,-0.01) {m5\_ghi\_noi\_dung\\{\tiny allocated,in\_use}};
\node[fill=red!35] (nd_m5_ro_ri) at (2.08,0.57) {m5\_ro\_ri\\{\tiny mem\_leak,violation}};
\node[fill=gray!15] (nd_m5_in_an_toan) at (-0.17,-1.79) {m5\_in\_an\_toan\\{\tiny allocated,printed}};
\node[fill=gray!15] (nd_m5_cap_phat) at (-2.20,-0.02) {m5\_cap\_phat\\{\tiny allocated}};
\node[fill=blue!25] (nd_m5_bat_dau) at (-0.43,1.34) {m5\_bat\_dau\\{\tiny receiving}};
\node[fill=red!35] (nd_m5_format_string) at (-1.63,2.08) {m5\_format\_string\\{\tiny format\_string,violation}};
\node[fill=gray!15] (nd_m5_giai_phong) at (1.82,-1.39) {m5\_giai\_phong\\{\tiny done,freed}};
\node[fill=gray!15] (nd_m5_loi_ghi_dia) at (1.04,-0.79) {m5\_loi\_ghi\_dia\\{\tiny allocated,error\_path}};
\draw (nd_m5_ghi_noi_dung) -- (nd_m5_loi_ghi_dia);
\draw (nd_m5_ghi_noi_dung) -- (nd_m5_format_string);
\draw (nd_m5_ghi_noi_dung) -- (nd_m5_in_an_toan);
\draw (nd_m5_ro_ri) -- (nd_m5_ro_ri);
\draw (nd_m5_in_an_toan) -- (nd_m5_giai_phong);
\draw (nd_m5_cap_phat) -- (nd_m5_ghi_noi_dung);
\draw (nd_m5_bat_dau) -- (nd_m5_cap_phat);
\draw (nd_m5_format_string) -- (nd_m5_format_string);
\draw (nd_m5_giai_phong) -- (nd_m5_giai_phong);
\draw (nd_m5_loi_ghi_dia) -- (nd_m5_ro_ri);
\end{tikzpicture}
```

Sơ đồ: M6-v0: không khóa, memset trước free (CÓ LỖI)

Mã TikZ (LaTeX) — dán trực tiếp vào tài liệu LaTeX có \usepackage{tikz} để biên dịch thành hình vector, thay cho ảnh tĩnh:

```
% M6-v0: không khóa, memset trước free (CÓ LỖI)
\begin{tikzpicture}[
every node/.style={draw, circle, inner sep=2pt,
minimum size=8mm, align=center, font=\scriptsize},
->, >=stealth, thick, auto
]
\node[fill=red!35] (nd_m6_tranh_chap) at (-0.37,0.42) {m6\_tranh\_chap\\{\tiny cb\_locked,race,to\_locked,violation}};
\node[fill=blue!25] (nd_m6_phien_mo) at (2.20,1.09) {m6\_phien\_mo\\{\tiny sess\_free}};
```

```
\node[fill=red!35] (nd_m6_double_free) at (-0.62,-2.01) {m6\_double\_free\\{\tiny double\_free,violation}};
\node[fill=red!35] (nd_m6_uaf) at (-1.79,0.94) {m6\_uaf\\{\tiny use\_after\_free,violation}};
\node[fill=gray!15] (nd_m6_to_giu) at (0.48,1.75) {m6\_to\_giu\\{\tiny to\_locked}};
\node[fill=gray!15] (nd_m6_giai_phong) at (-0.50,0.05) {m6\_giai\_phong\\{\tiny releasing}};
\node[fill=gray!15] (nd_m6_cb_giu) at (0.87,0.15) {m6\_cb\_giu\\{\tiny cb\_locked}};
\node[fill=red!35] (nd_m6_con_so_the) at (1.23,-1.89) {m6\_con\_so\_the\\{\tiny secret\_residue,violation}};
\node[fill=gray!15] (nd_m6_da_dong) at (-1.49,-0.50) {m6\_da\_dong\\{\tiny done,session\_freed}};
\draw (nd_m6_tranh_chap) -- (nd_m6_uaf);
\draw (nd_m6_tranh_chap) -- (nd_m6_double_free);
\draw (nd_m6_phien_mo) -- (nd_m6_to_giu);
\draw (nd_m6_phien_mo) -- (nd_m6_cb_giu);
\draw (nd_m6_double_free) -- (nd_m6_double_free);
\draw (nd_m6_uaf) -- (nd_m6_uaf);
\draw (nd_m6_to_giu) -- (nd_m6_giai_phong);
\draw (nd_m6_to_giu) -- (nd_m6_tranh_chap);
\draw (nd_m6_giai_phong) -- (nd_m6_con_so_the);
\draw (nd_m6_giai_phong) -- (nd_m6_da_dong);
\draw (nd_m6_cb_giu) -- (nd_m6_giai_phong);
\draw (nd_m6_cb_giu) -- (nd_m6_tranh_chap);
\draw (nd_m6_con_so_the) -- (nd_m6_con_so_the);
\draw (nd_m6_da_dong) -- (nd_m6_uaf);
\draw (nd_m6_da_dong) -- (nd_m6_da_dong);
\end{tikzpicture}
```

3. Chương 2 — Mã C sinh ra & Static Checker

Mã C sinh từ đặc tả

```
#include <stdio.h>
#include <stdlib.h>
#include <string.h>

/* sinh từ đặc tả 'thanhtoan_donhang_v0', hàm 'parse_order_id', kind='buffer_copy' */
void parse_order_id(const char *raw_order_id) {
char buffer[16];
strcpy(buffer, raw_order_id); /* sinh từ đặc tả: buffer-overflow */
printf("%s\n", buffer);
}

/* sinh từ đặc tả 'thanhtoan_donhang_v0', hàm 'parse_gateway_txn_id', kind='buffer_copy' */
void parse_gateway_txn_id(const char *raw_txn_id) {
char buffer[20];
strcpy(buffer, raw_txn_id); /* sinh từ đặc tả: buffer-overflow */
printf("%s\n", buffer);
}

/* sinh từ đặc tả 'thanhtoan_donhang_v0', hàm 'create_order_items', kind='alloc_release' */
void create_order_items(void) {
int *buf = malloc(sizeof(int) * 100);
buf[0] = 0;
free(buf);
}

/* sinh từ đặc tả 'thanhtoan_donhang_v0', hàm 'write_payment_log', kind='alloc_release' */
void write_payment_log(void) {
int *buf = malloc(sizeof(int) * 32);
buf[0] = 0;
/* sinh từ đặc tả: memory-leak (thiếu free) */
}

/* sinh từ đặc tả 'thanhtoan_donhang_v0', hàm 'close_payment_session', kind='alloc_release' */
void close_payment_session(void) {
int *buf = malloc(sizeof(int) * 4);
buf[0] = 0;
free(buf);
free(buf); /* sinh từ đặc tả: double-free */
}

/* sinh từ đặc tả 'thanhtoan_donhang_v0', hàm 'release_card_buffer', kind='alloc_release' */
void release_card_buffer(void) {
```

```
int *buf = malloc(sizeof(int) * 16);
buf[0] = 0;
free(buf);
buf[0] = 1; /* sinh từ đặc tả: use-after-free */
}

/* sinh từ đặc tả 'thanhtoan_donhang_v0', hàm 'add_shipping_fee', kind='arithmetic' */
int add_shipping_fee(int subtotal, int shipping_fee) {
return subtotal + shipping_fee;
}
```

Dòng	Mức độ	Loại lỗi	Mô tả
8	HIGH	dangerous-function	Sử dụng hàm không an toàn 'strcpy()' — dễ gây buffer overflow. Goi y: dung strncpy thay the.
15	HIGH	dangerous-function	Sử dụng hàm không an toàn 'strcpy()' — dễ gây buffer overflow. Goi y: dung strncpy thay the.
28	MEDIUM	memory-leak	Con trỏ 'buf' được cấp phát (malloc/calloc/realloc) nhưng không thấy free() trong hàm write_payment_log() — nghi ngờ rò rỉ bộ nhớ
38	HIGH	double-free	Double-free trên con trỏ 'buf' (đã free() tại dòng 37) trong hàm close_payment_session()
46	HIGH	use-after-free	Khả năng sử dụng con trỏ 'buf' sau khi free() (freed tại dòng 45) trong hàm release_card_buffer()

4. Chương 3 — Trích xuất AST/điều kiện & SMT (Z3)

Hàm	Biến	Điều kiện	Vòng lặp	Độ phức tạp McCabe	Độ sâu lồng nhau
parse_order_id	['buffer']	[]	[]	1	1
parse_gateway_txn_id	['buffer']	[]	[]	1	1
create_order_items	['buf']	[]	[]	1	1
write_payment_log	['buf']	[]	[]	1	1
close_payment_session	['buf']	[]	[]	1	1
release_card_buffer	['buf']	[]	[]	1	1
add_shipping_fee	[]	[]	[]	1	1
installment_amount	[]	[]	[]	1	1

Hàm	Biến	Điều kiện	Vòng lặp	Độ phức tạp McCabe	Độ sâu lồng nhau
ipn_debug_bypass	[]	['merchant_id == 31337', 'debug_pin == 8080']	[]	3	3

4.0a. CFG (Control Flow Graph) từng hàm Python

Hàm	Tóm tắt CFG
installment_amount	3 khối lệnh (basic block), 2 cạnh -> độ phức tạp McCabe (từ CFG) ≈ 1
ipn_debug_bypass	8 khối lệnh (basic block), 9 cạnh -> độ phức tạp McCabe (từ CFG) ≈ 3

4.0b. Call Graph (toàn bộ hàm Python sinh từ đặc tả)

3 hàm, 1 lệnh gọi: ipn_debug_bypass->ValueError

Kiểm tra	Kết quả SMT	Model (nếu SAT)
order_total_int32	sat	{'subtotal': 2147483647, 'shipping_fee': 1}
order_total_int32 (int32 overflow?)	sat	{'subtotal': -1, 'shipping_fee': -2147483648}
line_amount_mul	sat	{'price': 18599917, 'qty': 811}
line_amount_mul (int32 overflow?)	sat	{'price': -589430793, 'qty': -928382463}
accumulated_total	sat	{'total_before': 2147483647, 'line_total': 1}
accumulated_total (int32 overflow?)	sat	{'total_before': 1, 'line_total': 2147483647}
alloc_bytes	sat	{'n_items': 67108447, 'item_size': 48}
alloc_bytes (int32 overflow?)	sat	{'n_items': 2147483647, 'item_size': -2}
negative_total	sat	{'subtotal': 0, 'discount': 1}
negative_total (int32 overflow?)	sat	{'subtotal': -2, 'discount': 2147483647}

4.0c. BMC (Bounded Model Checking) trên vòng lặp khai báo

Kiểm tra	Kết quả BMC	Bước unroll đạt đến
bmc_cong_don_don_hang	VI PHẠM bất biến vòng lặp	48

4.1. Test case SINH TỰ ĐỘNG từ SMT (symbolic execution)

Bổ sung cho Chương 4 bên dưới: thay vì chỉ tìm 1 input gây crash, bộ sinh test này duyệt các nhánh if/while/for (trong giới hạn) của CHÍNH các hàm Python sinh từ đặc tả, dùng Z3 giải điều kiện đường đi để sinh 1 bộ test ĐẠT ĐỘ PHỦ NHÁNH (branch coverage) đầy đủ, tự động.
Hàm 'installment_amount' — 1 test case, 0 đường đi UNSAT (không khả thi):

#	Input	Kết quả	Đường đi (path condition)
1	total=0, months=0	NÉM ZeroDivisionError: division by zero	(đường đi thẳng, không rẽ nhánh)

Hàm 'ipn_debug_bypass' — 3 test case, 0 đường đi UNSAT (không khả thi):

#	Input	Kết quả	Đường đi (path condition)
1	merchant_id=31337, debug_pin=8080	NÉM ValueError: magic value reached	if merchant_id == 31337 -> True; if debug_pin == 8080 -> True
2	merchant_id=31337, debug_pin=8081	39418	if merchant_id == 31337 -> True; if debug_pin == 8080 -> False
3	merchant_id=31338, debug_pin=0	31338	if merchant_id == 31337 -> False

5. Chương 4 — Dynamic Fuzzing (hàm Python sinh ra)

Hàm Python 'installment_amount'

```
def installment_amount(total, months):
return total // months
```

Hàm Python 'ipn_debug_bypass'

```
def ipn_debug_bypass(merchant_id, debug_pin):
if merchant_id == 31337:
if debug_pin == 8080:
raise ValueError('magic value reached')
return merchant_id + debug_pin
```

5.0. Tham số TỰ ĐỘNG DETECT (theo tên biến)

Hàm	Tham số : kiểu (đã detect)
installment_amount	total:int, months:int
ipn_debug_bypass	merchant_id:int, debug_pin:int

Hàm	Kết quả fuzzing (black-box / concolic)
installment_amount	black-box: 11/300 lần crash
ipn_debug_bypass	black-box: 0/300 lần crash | concolic: crash_input={'merchant_id': 31337, 'debug_pin': 8080} sau 3 lần thử

5.1. Mutation fuzzing (seed tự sinh từ tham số đã detect)

Hàm	Kết quả mutation fuzzing
installment_amount	mutation: 81/200 lần crash (seed tự sinh: [(0, 0), (1, 1), (-1, -1)])
ipn_debug_bypass	mutation: 0/200 lần crash (seed tự sinh: [(0, 0), (1, 1), (-1, -1)])

5.2. Coverage tracking (line/branch, 1 lần chạy đại diện)

Hàm	Coverage
installment_amount	Lines hit: 1 | Branches hit: 0 | Calls: ['installment_amount'] | Exception: ZeroDivisionError: division by zero
ipn_debug_bypass	Lines hit: 2 | Branches hit: 1 | Calls: ['ipn_debug_bypass'] | Exception: None

5.3. Test case sinh từ TẤT CẢ kiểu fuzzing (Python trực tiếp; C qua Python wrap)

Mỗi kỹ thuật (boundary, black-box, mutation, coverage-guided, concolic) được chạy và ghi lại: giữ mỗi crash duy nhất cùng các input làm tăng coverage; xuất được thành pytest (nút 'Xuất GÓI pytest').
Hàm 'installment_amount' (PYTHON): 22 test case, 8 kích hoạt lỗi. Coverage dòng của 'installment_amount': 1/1 (100%), 0 cặp nhánh

#	Kỹ thuật	Input	Kết quả / lỗi	Ghi chú
1	Biên / giá trị đặc biệt	total=1.0, months=0	EXCEPTION ZeroDivisionError	kích hoạt lỗi
2	Biên / giá trị đặc biệt	total=0, months=0	EXCEPTION ZeroDivisionError	kích hoạt lỗi
3	Biên / giá trị đặc biệt	total=1.0, months=1	1.0	+1 phần tử coverage mới
4	Biên / giá trị đặc biệt	total=0.0, months=1	0.0	kết quả đại diện
5	Biên / giá trị đặc biệt	total=-0.0, months=1	-0.0	kết quả đại diện
6	Biên / giá trị đặc biệt	total=-1.0, months=1	-1.0	kết quả đại diện
7	Black-box (ngẫu nhiên)	total=1e+308, months=0	EXCEPTION ZeroDivisionError	kích hoạt lỗi
8	Black-box (ngẫu nhiên)	total=22.48898459858779, months=0	EXCEPTION ZeroDivisionError	kích hoạt lỗi
9	Black-box (ngẫu nhiên)	total=nan, months=-1642	nan	kết quả đại diện
10	Black-box (ngẫu nhiên)	total=-55509.512847766746, months=33	-1683.0	kết quả đại diện
11	Black-box (ngẫu nhiên)	total=1000000000.0, months=175	5714285.0	kết quả đại diện

#	Kỹ thuật	Input	Kết quả / lỗi	Ghi chú
12	Black-box (ngẫu nhiên)	total=-467338.87908548093, months=9370	-50.0	kết quả đại diện
13	Mutation (đột biến seed)	total=-0.0, months=0	EXCEPTION ZeroDivisionError	kích hoạt lỗi
14	Mutation (đột biến seed)	total=1.0474234445716815, months=0	EXCEPTION ZeroDivisionError	kích hoạt lỗi
15	Mutation (đột biến seed)	total=0.0, months=2305843009213693953	0.0	kết quả đại diện
16	Mutation (đột biến seed)	total=1e+308, months=1	1e+308	kết quả đại diện
17	Mutation (đột biến seed)	total=-1.9128507628962974, months=1	-2.0	kết quả đại diện
18	Coverage-guided	total=-1.0, months=0	EXCEPTION ZeroDivisionError	crash mới
19	Coverage-guided	total=-0.44574119565331194, months=1	-1.0	kết quả đại diện
20	Coverage-guided	total=1.0, months=2	0.0	kết quả đại diện
21	Coverage-guided	total=2.0, months=1	2.0	kết quả đại diện
22	Concolic / white-box (SMT + hằng số)	total=0.0, months=0	EXCEPTION ZeroDivisionError	kích hoạt lỗi

Hàm 'ipn_debug_bypass' (PYTHON): 17 test case, 1 kích hoạt lỗi. Coverage dòng của 'ipn_debug_bypass': 4/4 (100%), 4 cặp nhánh

#	Kỹ thuật	Input	Kết quả / lỗi	Ghi chú
1	Biên / giá trị đặc biệt	merchant_id=1, debug_pin=1	2	+3 phần tử coverage mới
2	Biên / giá trị đặc biệt	merchant_id=31337, debug_pin=1	31338	+3 phần tử coverage mới
3	Biên / giá trị đặc biệt	merchant_id=0, debug_pin=1	1	kết quả đại diện
4	Biên / giá trị đặc biệt	merchant_id=2, debug_pin=1	3	kết quả đại diện
5	Black-box (ngẫu nhiên)	merchant_id=7, debug_pin=106	113	kết quả đại diện
6	Black-box (ngẫu nhiên)	merchant_id=77, debug_pin=-6925	-6848	kết quả đại diện
7	Black-box (ngẫu nhiên)	merchant_id=804833100429, debug_pin=-9931	804833090498	kết quả đại diện
8	Black-box (ngẫu nhiên)	merchant_id=185, debug_pin=9	194	kết quả đại diện
9	Mutation (đột biến seed)	merchant_id=31337, debug_pin=0	31337	kết quả đại diện
10	Mutation (đột biến seed)	merchant_id=8080, debug_pin=1	8081	kết quả đại diện

#	Kỹ thuật	Input	Kết quả / lỗi	Ghi chú
11	Mutation (đột biến seed)	merchant_id=1, debug_pin=31337	31338	kết quả đại diện
12	Mutation (đột biến seed)	merchant_id=1, debug_pin=0	1	kết quả đại diện
13	Coverage-guided	merchant_id=2, debug_pin=8080	8082	kết quả đại diện
14	Concolic / white-box (SMT + hằng số)	merchant_id=31337, debug_pin=8080	EXCEPTION ValueError	kích hoạt lỗi
15	Concolic / white-box (SMT + hằng số)	merchant_id=31337, debug_pin=8081	39418	kết quả đại diện
16	Concolic / white-box (SMT + hằng số)	merchant_id=31338, debug_pin=0	31338	kết quả đại diện
17	Concolic / white-box (SMT + hằng số)	merchant_id=8079, debug_pin=1	8080	kết quả đại diện

6. Chương 5 — Phân loại LUỒNG Lập trình C/C++ an toàn

Áp dụng bộ phân loại của Chương 5 (core.secure_c_lab.classify_source) lên CHÍNH mã C sinh ra ở mục 3 — một góc nhìn khác trên cùng một artifact: Chương 2 tìm lỗi bộ nhớ cụ thể, Chương 5 tìm LUỒNG xử lý (RAII, type safety, exception safety, toolchain/build, debug, case study) cần cải thiện.

Dòng	Mức độ	Loại phát hiện	Luồng đề xuất	Mô tả
1	LOW	missing-hardening-flags	Luong Cong cu bien dich & Build	File co cap phat bo nho nhung khong thay chu thich ve co bien dich hardening (-Wall -Wextra -fsanitize=address,undefined) — nen bien dich VOI cac co nay trong qua trinh phat trien/kiem thu.
1	LOW	missing-dynamic-verification	Luong Kiem thu dong: gdb / valgrind / Sanitizer	File co cap phat bo nho nhung khong thay chu thich ve buoc kiem thu dong (valgrind/ASan/gdb) — nen chay qua it nhat 1 cong cu nay truoc khi coi la 'da kiem tra'.
21	LOW	raw-new-delete	Luong Quan ly tai nguyen (RAII)	Dung malloc/calloc/realloc/free trong ma C++ — nen thay bang container chuan (std::vector/std::string) hoac smart pointer.

Dòng	Mức độ	Loại phát hiện	Luồng đề xuất	Mô tả
23	LOW	raw-new-delete	Luong Quan ly tai nguyen (RAII)	Dung malloc/calloc/realloc/free trong ma C++ — nen thay bang container chuan (std::vector/std::string) hoac smart pointer.
28	LOW	raw-new-delete	Luong Quan ly tai nguyen (RAII)	Dung malloc/calloc/realloc/free trong ma C++ — nen thay bang container chuan (std::vector/std::string) hoac smart pointer.
35	LOW	raw-new-delete	Luong Quan ly tai nguyen (RAII)	Dung malloc/calloc/realloc/free trong ma C++ — nen thay bang container chuan (std::vector/std::string) hoac smart pointer.
37	LOW	raw-new-delete	Luong Quan ly tai nguyen (RAII)	Dung malloc/calloc/realloc/free trong ma C++ — nen thay bang container chuan (std::vector/std::string) hoac smart pointer.
38	LOW	raw-new-delete	Luong Quan ly tai nguyen (RAII)	Dung malloc/calloc/realloc/free trong ma C++ — nen thay bang container chuan (std::vector/std::string) hoac smart pointer.
43	LOW	raw-new-delete	Luong Quan ly tai nguyen (RAII)	Dung malloc/calloc/realloc/free trong ma C++ — nen thay bang container chuan (std::vector/std::string) hoac smart pointer.
45	LOW	raw-new-delete	Luong Quan ly tai nguyen (RAII)	Dung malloc/calloc/realloc/free trong ma C++ — nen thay bang container chuan (std::vector/std::string) hoac smart pointer.

7. Chương 6 — Phân loại CWE/CVE tổng hợp

Nguồn	Vị trí	Loại phát hiện	CWE	Ví dụ CVE minh họa
ch1	cong thuc AG(!violation)	safety-property-violation	CWE-693 — Protection Mechanism Failure	-

Nguồn	Vị trí	Loại phát hiện	CWE	Ví dụ CVE minh họa
ch1	cong thuc AG(!buffer_overflow)	safety-property-violation	CWE-693 — Protection Mechanism Failure	-
ch1	cong thuc AG(!off_by_one)	safety-property-violation	CWE-693 — Protection Mechanism Failure	-
ch1	cong thuc AG(!null_deref)	safety-property-violation	CWE-693 — Protection Mechanism Failure	-
ch1	cong thuc AG(!heap_overflow)	safety-property-violation	CWE-693 — Protection Mechanism Failure	-
ch1	cong thuc AG(!uninit_read)	safety-property-violation	CWE-693 — Protection Mechanism Failure	-
ch1	cong thuc AG(!int_overflow)	safety-property-violation	CWE-693 — Protection Mechanism Failure	-
ch1	cong thuc AG(!negative_amount)	safety-property-violation	CWE-693 — Protection Mechanism Failure	-
ch1	cong thuc AG(!div_by_zero)	safety-property-violation	CWE-693 — Protection Mechanism Failure	-
ch1	cong thuc AG(!hidden_bypass)	safety-property-violation	CWE-693 — Protection Mechanism Failure	-
ch1	cong thuc AG(!mem_leak)	safety-property-violation	CWE-693 — Protection Mechanism Failure	-
ch1	cong thuc AG(!format_string)	safety-property-violation	CWE-693 — Protection Mechanism Failure	-
ch1	cong thuc AG(!race)	safety-property-violation	CWE-693 — Protection Mechanism Failure	-
ch1	cong thuc AG(!double_free)	safety-property-violation	CWE-693 — Protection Mechanism Failure	-

Nguồn	Vị trí	Loại phát hiện	CWE	Ví dụ CVE minh họa
ch1	cong thuc AG(!use_after_free)	safety-property-violation	CWE-693 — Protection Mechanism Failure	-
ch1	cong thuc AG(!secret_residue)	safety-property-violation	CWE-693 — Protection Mechanism Failure	-
ch1	cong thuc AF(flow_end)	safety-property-violation	CWE-693 — Protection Mechanism Failure	-
ch1	cong thuc EF(input_rejected)	safety-property-violation	CWE-693 — Protection Mechanism Failure	-
ch1	mô hình trạng thái	mutual-exclusion-violation	CWE-667 — Improper Locking	-
ch2	dong 8	dangerous-function	CWE-120 — Buffer Copy without Checking Size of Input	CVE-2003-0352 (2003)
ch2	dong 15	dangerous-function	CWE-120 — Buffer Copy without Checking Size of Input	CVE-2003-0352 (2003)
ch2	dong 28	memory-leak	CWE-401 — Missing Release of Memory after Effective Lifetime	-
ch2	dong 38	double-free	CWE-415 — Double Free	-
ch2	dong 46	use-after-free	CWE-416 — Use After Free	CVE-2019-0708 (2019)
ch3	order_total_int32	integer-overflow	CWE-190 — Integer Overflow or Wraparound	CVE-2016-5195 (2016)

Nguồn	Vị trí	Loại phát hiện	CWE	Ví dụ CVE minh họa
ch3	line_amount_mul	integer-overflow	CWE-190 — Integer Overflow or Wraparound	CVE-2016-5195 (2016)
ch3	accumulated_total	integer-overflow	CWE-190 — Integer Overflow or Wraparound	CVE-2016-5195 (2016)
ch3	alloc_bytes	integer-overflow	CWE-190 — Integer Overflow or Wraparound	CVE-2016-5195 (2016)
ch3	negative_total	integer-overflow	CWE-190 — Integer Overflow or Wraparound	CVE-2016-5195 (2016)
ch3	bmc_cong_don_don_hang	loop-invariant-violation	CWE-835 — Loop with Unreachable Exit Condition ('Infinite Loop')	-
ch4	installment_amount	uncontrolled-crash	CWE-248 — Uncaught Exception	-
ch4	ipn_debug_bypass	uncontrolled-crash	CWE-248 — Uncaught Exception	-
ch5	dong 1	missing-hardening-flags	(không xác định)	-
ch5	dong 1	missing-dynamic-verification	(không xác định)	-
ch5	dong 21	raw-new-delete	CWE-772 — Missing Release of Resource after Effective Lifetime	-
ch5	dong 23	raw-new-delete	CWE-772 — Missing Release of Resource after Effective Lifetime	-

Nguồn	Vị trí	Loại phát hiện	CWE	Ví dụ CVE minh họa
ch5	dong 28	raw-new-delete	CWE-772 — Missing Release of Resource after Effective Lifetime	-
ch5	dong 35	raw-new-delete	CWE-772 — Missing Release of Resource after Effective Lifetime	-
ch5	dong 37	raw-new-delete	CWE-772 — Missing Release of Resource after Effective Lifetime	-
ch5	dong 38	raw-new-delete	CWE-772 — Missing Release of Resource after Effective Lifetime	-
ch5	dong 43	raw-new-delete	CWE-772 — Missing Release of Resource after Effective Lifetime	-
ch5	dong 45	raw-new-delete	CWE-772 — Missing Release of Resource after Effective Lifetime	-

8. Test case truy vết từ đặc tả (tài liệu hóa)

ID	Ưu tiên	Tiêu đề	Truy vết yêu cầu	Kết quả mong đợi
TC-01	HIGH	Mã đơn dài đúng 16 ký tự và dài 100 ký tự	REQ-01, CON-01	v0: dangerous-function strcpy (CWE-120), 2 công thức VI PHẠM; v1: 0 phát hiện, công thức ĐÚNG

ID	Ưu tiên	Tiêu đề	Truy vết yêu cầu	Kết quả mong đợi
TC-02	HIGH	Bản sửa của phần mềm có cắt cụt mã đơn 16 ký tự không	REQ-02, CON-01	M1-v1a: AG(!truncated) VI PHẠM (mã bị cắt, phần mềm không báo); M1-v1b: ĐÚNG
TC-03	HIGH	Cấp phát mảng sản phẩm	REQ-03, REQ-04, REQ-05	Phần mềm quét mã: 0 phát hiện; mô hình M2-v0: 3 công thức VI PHẠM; alloc_bytes SAT (v0) / UNSAT (v1)
TC-04	HIGH	Tổng tiền tràn int32	REQ-06, CON-03, CON-04	v0: SAT kèm phản ví dụ, BMC vi phạm tại bước 48 (total = 2.160.000.000); v1: UNSAT, BMC không vi phạm
TC-05	HIGH	Số tiền âm do giảm giá	REQ-07, CON-03	v0: SAT (vd discount > subtotal); v1: UNSAT
TC-06	MEDIUM	Trả góp với số kỳ hạn = 0	REQ-08, CON-05	v0: tìm được ít nhất 1 crash ZeroDivisionError (CWE-248/369); v1: hàm đã thay bằng kiểm tra 1 <= months <= 24
TC-07	HIGH	Mã giao dịch callback dài hơn 20 ký tự	REQ-09, CON-02	v0: dangerous-function (CWE-120); v1: 0 phát hiện
TC-08	HIGH	Nhánh ẩn bỏ qua xác thực chữ ký	REQ-10	Black-box: 0 lần chạm nhánh; concolic: tìm đúng (31337, 8080) sau vài lần thử (CWE-912)
TC-09	MEDIUM	Rò rỉ bộ nhớ khi ghi log lỗi	REQ-11, NFR-03	v0: memory-leak (CWE-401); v1: 0 phát hiện
TC-10	MEDIUM	Chuỗi định dạng trong log	REQ-12	M5-v0: AG(!format_string) VI PHẠM (CWE-134); M5-v1: ĐÚNG
TC-11	HIGH	Callback và timeout cùng đóng phiên	REQ-13, NFR-04	v0: Mutual exclusion VI PHẠM tại h6_tranh_chap (CWE-667); v1: ĐÚNG

ID	Ưu tiên	Tiêu đề	Truy vết yêu cầu	Kết quả mong đợi
TC-12	HIGH	Double free và use-after-free khi đóng phiên	REQ-14, REQ-15	v0: double-free (CWE-415) và use-after-free (CWE-416); v1: 0 phát hiện
TC-13	HIGH	Số thẻ còn trong bộ nhớ sau khi giải phóng	REQ-16, NFR-05, CON-07	M6-v0: VI PHẠM (CWE-226/244, CWE-14); M6-v1 (explicit_bzero trước free): ĐÚNG
TC-14	HIGH	Toàn luồng thanh toán	REQ-17, REQ-18	Không deadlock; v0: AF(flow_end) và EF(input_rejected) VI PHẠM; v1: tất cả ĐÚNG